

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)

Course 1: GRC101 - Introduction to Governance, Risk, and Compliance

Week 3 Lab Assignment: Compliance Management and Reporting

Full Name	MERCY RACHAEL AJAYI
Registration Number	C11/26/CGRCE/17219
Cohort / Batch	CGRCE Cohort 11
Course Title	Introduction to GRC Engineering
Date Submitted	29 July, 2026

Lab Objectives:

This lab assignment is designed to help you:

- Understand compliance management processes and documentation requirements
- Develop skills in creating compliance documentation and reports
- Apply compliance monitoring and measurement techniques
- Gain practical experience in compliance program evaluation

Instructions:

Complete all parts of this lab assignment. Submit your completed document to your instructor by the due date. All answers should be typed directly into this document.

Part 1: Compliance Documentation Development (30 points)

For this exercise, you will develop key compliance documentation for a fictional organization. Imagine you are the Compliance Officer for TechSecure Solutions, a mid-sized software development company that handles sensitive customer data and is subject to various regulations including GDPR and industry standards like ISO 27001.

Create the following compliance documentation:

1. Develop a Compliance Policy Statement (5-7 sentences) that outlines TechSecure Solutions' commitment to regulatory compliance. Include the purpose, scope, key principles, and responsibilities. (10 points)

TechSecure Solutions is committed to complying with all applicable laws, regulations, and industry standards that apply to its business operations, including GDPR and ISO 27001 requirements. This policy applies to every employee, contractor, third-party vendor, and other individual who has access to company systems, customer data, and information across all departments and locations where TechSecure operates. The purpose of this policy is to protect the confidentiality, integrity, and availability of customer information, maintain the trust clients place in the organization, and meet its legal and regulatory responsibilities. TechSecure Solutions is guided by the principles of accountability, transparency, and continuous improvement, which means compliance is treated as an ongoing responsibility rather than a one-time task. All employees are expected to understand and follow the company's compliance policies and procedures and report any suspected violations. The Compliance Officer is responsible for coordinating compliance activities, monitoring requirements, and reporting significant compliance issues to management, while department heads are responsible for ensuring compliance within their areas. The company will regularly review its compliance program and take corrective action when gaps or violations are identified.

2. Create a Compliance Monitoring Plan that includes at least five specific monitoring activities, their frequency, responsible parties, and how results will be documented. Present this in a table format. (10 points)

Monitoring Activity	Frequency	Responsible Party	How Results will be Documented
Review of compliance policies and procedures.	Quarterly	Compliance Officer	A policy review log will be maintained to record the policies reviewed, changes made, and outstanding updates.
Review of access to systems containing sensitive customer data, including access logs and user accounts.	Monthly	IT/Security Team and Compliance Officer	Access review reports will be completed and maintained as compliance records. Any unnecessary or unauthorized access identified during the review will be documented and removed. The completed access review sheet will be saved in the compliance shared

			drive, and any flagged issues will be reported to the Compliance Officer via email for further action.
Employee compliance training completion tracking.	Monthly	HR and Compliance Officer	Training completion records will be maintained and employees who have not completed required training will be followed up.
Review of GDPR and other applicable regulatory requirements.	Quarterly	Compliance Officer and Legal Team	Regulatory review records will be maintained to document any new or changed regulatory requirements, their potential impact on the company, and the actions required to address them.
Internal compliance review of key processes.	Quarterly	Compliance Officer	Findings and recommendations will be documented in a compliance review report and shared with department heads and management.

3. Design a Compliance Incident Response Procedure that outlines the steps to be taken when a potential compliance violation is identified. Include at least 6 steps with brief descriptions of each. (10 points)

I. Identify and Report any Potential Violation

Any suspected or potential compliance violation should be identified and reported immediately to the Compliance Officer or through the organization's confidential reporting channel.

II. Record and Document the Incident

The Compliance Officer will document the available information about the incident, including what happened, when it occurred, the systems or processes involved, and the people or data that may have been affected.

III. Assess the Incident

The Compliance Officer will conduct an initial assessment to determine the seriousness of the issue, the laws, regulations, or internal requirements that may have been violated, and whether there is an immediate risk to the company or affected individuals.

IV. Contain the Incident

If the issue is ongoing, immediate steps will be taken to limit further impact and prevent the situation from getting worse. This may include restricting access to an affected system or temporarily stopping an affected process.

V. Investigate the Cause

A detailed investigation will be conducted to understand what happened, why it happened, and whether the issue was caused by a weakness in a policy, process, system, or employee action.

VI. Correct the Issue

Once the incident is contained, corrective steps will be taken to fix the underlying problem, such as updating a process, revoking access, or patching a system so the violation does not continue.

VII. Escalate and Report Where Necessary

Serious compliance incidents will be escalated to senior management and relevant internal stakeholders. Where applicable laws or regulations require notification to a regulatory authority or affected individuals, the company will make the required reports within the appropriate timeframe.

VIII. Implement Corrective Actions

The company will identify and implement corrective actions to address the root cause of the violation, resolve the issue, and prevent a similar incident from happening again.

IX. Close and Review the Incident

The incident will be closed formally once the investigation and corrective actions have been completed. The Compliance Officer will document the outcome and review lessons learned to determine whether any policies, procedures, training, or controls need to be updated or improved.

Part 2: Compliance Metrics and KPIs (25 points)

Effective compliance management requires measuring and reporting on key metrics. For this exercise, you will develop a set of compliance metrics and KPIs for TechSecure Solutions.

1. Identify and describe five key compliance metrics or KPIs that TechSecure Solutions should track. For each metric, explain what it measures, why it's important, how it should be calculated, and what the target or benchmark should be. (15 points)

- **Compliance Training Completion Rate**

This measures the percentage of employees who have completed required compliance training within the reporting period. It matters because untrained employees are more likely to make compliance errors or fail to recognize risks in their day-to-day work. It is calculated as **(Number of employees who completed required training ÷ Total number of employees required to**

complete training) $\times 100$.

Target: 100% completion each quarter, with 95% as the minimum acceptable rate. Any outstanding training should be completed within the required timeframe.

- **Number of compliance incidents reported**

This measures the number of confirmed compliance violations during a specific period. It matters because it helps the company identify whether there are recurring compliance problems and whether its policies and controls are working effectively in practice. It is calculated as the **(Total number of confirmed compliance incidents during the reporting period)**.

Target: The company should aim for a downward trend in confirmed compliance violations over time, while ensuring that all reported incidents are properly investigated and addressed promptly.

- **Audit Finding Closure Rate**

This measures the percentage of audit findings that have been resolved within the agreed timeframe. It shows whether the company is taking action to address identified compliance gaps instead of leaving them unresolved. It is calculated as: **(Number of audit findings closed on time $\div$ Total number of audit findings due for closure) $\times 100$.**

Target: At least 90% of findings should be closed within the agreed timeframe, with no overdue high-risk findings.

- **Regulatory Compliance Requirement Completion Rate**

This measures the percentage of identified applicable regulatory requirements that have been addressed by the company. It helps management understand whether the organization is keeping up with its regulatory responsibilities and taking action where required. It is calculated as: **(Number of applicable requirements with completed compliance actions $\div$ Total number of applicable requirements) $\times 100$.**

Target: At least 95%, with high-risk regulatory requirements addressed immediately.

- **Vendor compliance rate**

This measures the percentage of active vendors that have a signed Data Processing Agreement and a completed security assessment on file. Third-party vendors can be a major source of risk because they may have access to company systems or customer data. It is calculated as: **(Number of compliant vendors $\div$ Total number of active vendors) $\times 100$.**

Target: 100%, with 90% as the minimum acceptable rate.

2. Design a mock-up of a quarterly compliance dashboard that would be presented to the executive team. Describe what information would be included, how it would be

visualized, and why this information is valuable for executive decision-making. (10 points)

The dashboard would open with a row of four scorecards across the top: training completion rate, number of open audit findings, compliance incidents this quarter, and vendor compliance rate. Each scorecard would be color-coded red, yellow, or green so an executive can tell at a glance where attention is needed without reading through a full report. Below that, a trend line chart would show compliance incidents per quarter over the last four quarters, so the team can see whether things are improving or getting worse rather than just looking at a single snapshot. Next to it, a simple risk heat map broken down by department would highlight which areas carry the most outstanding risk. At the bottom, a short table would list the top open action items, each with an owner and a due date, so the executive team knows exactly what is being worked on and who is accountable. This layout matters for executive decision-making because leaders do not have time to read a full compliance report every quarter - they need a fast visual summary that tells them what is working, what is not, and where resources or attention should go next.

Part 3: Compliance Audit Preparation (25 points)

TechSecure Solutions is preparing for an ISO 27001 certification audit in three months. As the Compliance Officer, you need to prepare the organization for this important audit.

1. Create a pre-audit checklist with at least 10 specific items that should be reviewed or prepared before the ISO 27001 audit. For each item, briefly explain its importance to the audit process. (15 points)

- **Review all information security and compliance policies:** This ensures that policies are current, approved, and available to employees before the audit.
- **Review the organization's information security risk assessment:** The auditor will need evidence that the company has identified and assessed its information security risks.
- **Review the Risk Treatment Plan:** This shows how the organization plans to address the risks identified during the risk assessment.
- **Confirm that the Statement of Applicability is complete and current:** It helps demonstrate which applicable security controls have been selected and the reasons for their inclusion or exclusion.
- **Review internal audit results:** Internal audits help identify gaps before the certification audit and show that the organization monitors its ISMS.
- **Review and close outstanding corrective actions:** Open findings should be addressed before the audit, especially issues that could affect the organization's ability to meet requirements.
- **Confirm that management reviews have been completed:** Management review provides evidence that senior management is involved in reviewing the performance and effectiveness of the ISMS.
- **Review employee security and compliance training records:** This provides evidence that employees have received the required awareness and training.

- **Review access control records:** Access reviews help demonstrate that access to information and systems is properly managed and restricted to authorized users.
- **Review information security incident records:** This shows how the organization identifies, records, responds to, and learns from security incidents.
- **Review business continuity and recovery plans:** This helps confirm that the organization has considered how it will maintain important operations and recover from disruptions.
- **Conduct a mock audit:** A mock audit can help the organization identify missing evidence, weak areas, and employee preparedness before the actual certification audit.

2. Develop a communication plan for preparing employees for the upcoming audit. Include at least three different communication methods, the key messages for each, target audience, and timing. (10 points)

Communication Method	Key Message	Target Audience	Timing
All-staff email	Employees will be informed about the upcoming ISO 27001 audit, why the audit is taking place, when it will happen, and what they can generally expect during the audit.	All employees	Eight to six weeks before the audit
Department briefings led by managers	Managers will brief employees on their department-specific responsibilities and the types of evidence or questions their team may be asked to provide or respond to during the audit.	All departments, with more focus on teams with significant control responsibilities, such as IT and HR.	Three to four weeks before the audit
Intranet reminder page plus a day-of email	A quick reference page will be made available on the company intranet with answers to common questions and information on who employees should contact if they have questions or concerns during the audit. A short reminder email will also be sent to	All employees	The intranet page will be posted about one week before the audit, with a reminder email sent on the morning the audit begins.

	employees on the morning the audit begins.		
--	--	--	--

Part 4: Compliance Program Evaluation (20 points)

Case Study: FinTech Innovations

FinTech Innovations is a financial technology company that has been in operation for five years. They provide payment processing services and financial management software to small and medium-sized businesses. The company has grown rapidly from 20 to 150 employees and now serves clients in multiple countries.

The company established a compliance program three years ago when they reached 50 employees. The program consists of:

- A part-time Compliance Officer (who also serves as the Legal Counsel)
- A set of compliance policies that were developed when the program was established
- Annual compliance training for all employees
- Quarterly compliance reports to the executive team
- Ad-hoc compliance monitoring activities

Recently, the company experienced a compliance incident where they failed to update their privacy policies to reflect new regulatory requirements in one of their operating regions. This resulted in a small fine and negative publicity. The CEO has asked for an evaluation of the current compliance program to identify areas for improvement.

Based on this case study, answer the following questions:

1. Evaluate FinTech Innovations' current compliance program using the seven elements of an effective compliance program as a framework. Identify at least three strengths and three weaknesses of their current approach. (10 points)

Based on the case study, FinTech Innovations has some basic compliance structures in place, but the program has not developed at the same rate as the company. The company has grown from 20 to 150 employees and now operates in multiple countries, which means its compliance needs are more complex than they were when the program was first established.

I. Policies and Procedures

Strength: The company has compliance policies in place, which give employees some guidance on the organization's compliance expectations.

Weakness: The policies were created three years ago and have not been properly updated to reflect changes in regulatory requirements. This became clear when the company failed to update its privacy policies, which resulted in a fine and negative publicity.

II. Compliance Leadership and Oversight

Strength: The company has a Compliance Officer who is also the Legal Counsel. This means there is at least one person responsible for compliance matters and legal issues.

Weakness: Having only a part-time Compliance Officer may no longer be sufficient for a company that has grown to 150 employees and operates in multiple countries. The Compliance Officer may not have enough time or resources to properly manage the organization's growing compliance responsibilities.

III. Training and Communication

Strength: The company provides annual compliance training to all employees. This shows that management recognizes the importance of educating employees about compliance.

Weakness: Annual training on its own may not be enough to address new regulatory requirements or specific risks that employees face in their roles. The recent privacy policy issue also suggests that employees and relevant teams may need more regular updates when regulations change.

IV. Monitoring and Auditing

Strength: The company carries out some compliance monitoring activities and provides quarterly compliance reports to the executive team.

Weakness: The monitoring activities are described as ad-hoc, which means they may not be consistent or systematic. This can make it difficult to identify compliance gaps early. The failure to identify the new privacy requirements also shows that the company needs a more structured approach to monitoring regulatory changes and compliance obligations.

V. Reporting and Investigation

Strength: The company provides quarterly compliance reports to the executive team, which gives management some visibility into compliance matters.

Weakness: The case study does not show evidence of a formal process for employees to report potential compliance concerns or for those concerns to be consistently investigated. This is an area that should be strengthened as the organization grows.

VI. Enforcement and Discipline

Strength: The existing compliance program provides a basic framework of policies and training that can support enforcement of compliance expectations.

Weakness: The case study does not provide evidence of a clear and formal process for handling employee violations or applying disciplinary measures. The company should have clear consequences for non-compliance and ensure that these are applied consistently.

VII. Response and Corrective Action

Strength: The company has responded to the privacy policy incident and is now evaluating its compliance program. The CEO's request for an evaluation is a positive step toward improving the program.

Weakness: The fact that the privacy policy was not updated when regulatory requirements changed shows that the company needs a stronger process for identifying compliance gaps and implementing corrective actions before they result in fines or reputational damage.

Overall, FinTech Innovations has the basic foundation of a compliance program, including policies, employee training, compliance reporting, and a person responsible for compliance. However, the program appears to be more reactive than proactive. The company's rapid growth and expansion into multiple countries have increased its compliance responsibilities, but the program has not been sufficiently updated to match this growth. The recent privacy policy incident is an example of what can happen when regulatory changes are not properly monitored and compliance activities are not carried out consistently. The company should therefore strengthen its compliance resources, monitoring activities, regulatory change management, and corrective action processes.

2. Recommend five specific improvements to strengthen FinTech Innovations' compliance program. For each recommendation, explain the rationale and expected benefits. (10 points)

1. Hire a dedicated, full-time Compliance Officer separate from the Legal Counsel role. Rationale: removes the conflict of interest and gives compliance the dedicated attention a 150-person, multi-country company needs. Expected benefit: faster response to regulatory changes and clearer accountability.
2. Set up a scheduled policy review cycle, for example annually or whenever regulations change in an operating region. Rationale: this directly addresses the gap that caused the recent fine. Expected benefit: policies stay current as the company expands into new markets.
3. Replace ad-hoc monitoring with a structured monitoring plan that defines specific activities and how often each one happens. Rationale: consistent monitoring catches problems early instead of after a regulator or the press does. Expected benefit: lower risk of future fines and reputational damage.
4. Build a regulatory change tracking process, such as subscribing to regulatory updates for each operating region or using compliance software. Rationale: the company now operates across multiple countries where rules can change independently. Expected benefit: the company becomes proactive about compliance instead of reacting after something goes wrong.
5. Create a formal internal reporting channel, such as a whistleblower line, so employees can flag concerns outside of the quarterly report cycle. Rationale: right now it is not clear how issues would surface between reports. Expected benefit: earlier detection of problems and a stronger overall compliance culture.